



Šiaurės Korėjos Kibernetinių Grėsmių Kraštovaizdis 2025-2026

Kampanija „Contagious Interview“, dirbtinio intelekto
ginkluotė ir IT darbuotojų šešėlinė ekonomika.

Vykdomoji Santrauka: Evoliucionuojanti Grėsmė

01



Taktika

„Contagious Interview“. Socialinė inžinerija per darbo pokalbius, taikantis į kūrėjus kriptovaliutų ir finansų sektoriuose.

02



Inovacijos

AI Integracija. „ChatGPT“ ir „Cursor“ naudojimas kodo maskavimui; „Faceswapper.ai“ tapatybių klastojimui.

03



Mastelis

Pramoninis Lygis. Tūkstančiai taikinių, organizuotos IT darbuotojų generuojančios milijonines pajamas režimui.

04



Infrastruktūra

Legitimių Platformų Išnaudojimas. Piktnaudžiavimas „GitLab“, „Vercel“, „npm“ ir „LinkedIn“ paslaugomis.

Atakos Vektorius: „Užkrečiamas Interviu“ (The Contagious Interview)



1. Kontaktas

„Recruiteriai“ užmezga ryšį per socialinius tinklus.



2. Pasiūlymas

Siūlomas didelis atlyginimas, prašoma atlikti techninę „JavaScript“ užduotį.



3. Vykdymas

Auka atsisieničia ir paleidžia kodą savo įrenginyje.



4. Užkrėtimas

Aktyvuojami „BeaverTail“ arba „Ottercookie“ kenkėjai.

Taikiniai: 1000+ vardų sąrašuose (Kriptovaliutos, Finansai, NT, DI).

Pasitikėjimo Inžinerija: DI Arsenalas



← Faceswapper.ai
ir AI-headshots

Generuojami unikalūs veidai pasams ir profilams, kad praeitų tapatybės patikras (KYC).

Sintetinis Legitimumas

- **Tinklo Efektas:** Netikros tapatybės bendrauja tarpusavyje, rašo rekomendacijas.
- **Apgaulė:** Naudojami pritaikyti el. pašto domenai ir suklastoti įmonių profiliai ir suklastoti įmonių profiliai.
- **Saugumo apėjimas:** Apsimetama saugumo tyrėjas, kad 'ChatGPT' padėtų rašyti kenkėjišką kodą.

Techninė Analizė: Kenkėjiško Kodo Anatomija



The image shows a code editor window with a dark theme. The title bar indicates the file is named 'code .env'. The code is as follows:

```
RUNTIME_CONFIG_API_KEY="aHR0cHM6Ly9hcG..."  
  
try {  
  ...  
} catch (error) {  
  new Function.constructor(error)  
}  
  
if (isSandbox) {  
  terminate()  
}
```

Annotations with red arrows point to specific parts of the code:

- An arrow points from the text "Slėpimas .env failuose (Base64 koduotė)." to the value of the `RUNTIME_CONFIG_API_KEY` variable.
- An arrow points from the text "Klaidų Tvarkyklės (Error Handlers) vykdo kenkėjišką kodą." to the `new Function.constructor(error)` line.
- An arrow points from the text "„Ottercookie“ Smėlio Dėžės Detekcija." to the `if (isSandbox) { terminate(); }` block.

Metodas: Failų išskaidymas (iki 4 failų) apsunkina aptikimą.

Nauja Tendencija: DI Pagalba Programavime



Infrastruktūra ir Platinimas



GitLab

„Vercel“ Hostingas:

Kenkėjiški „loaderiai“ siunčia užklausas į legalius serverius.



Vercel

Malware
Delivery

VS Code Užduotys:

Kodas vykdomas per automatines redaktoriaus užduotis.

npm



Visual Studio
Code

Antraščių (Headers) Patikra:

Serveris atsiunčia kenkėjišką turinį tik gavęs teisingus raktus iš .env failo.

Užkulisiai: Šešėlinės IT Darbuotojų Cėlės



Tai ne pavieniai hakeriai.
Tai **valstybės remiamos,**
karinė disciplina
parentos struktūros.

Atvejo Analizė: Kil-Nam Kang Cele (Finansai)

\$1.64 mln. USD

Pajamos per 2022–2025 m.



Lokacija: Pekinas, Kinija

Prisidengiama „Kim Il-sung universiteto tyrimų centro“ statusu.

IP: 111.197.183.74



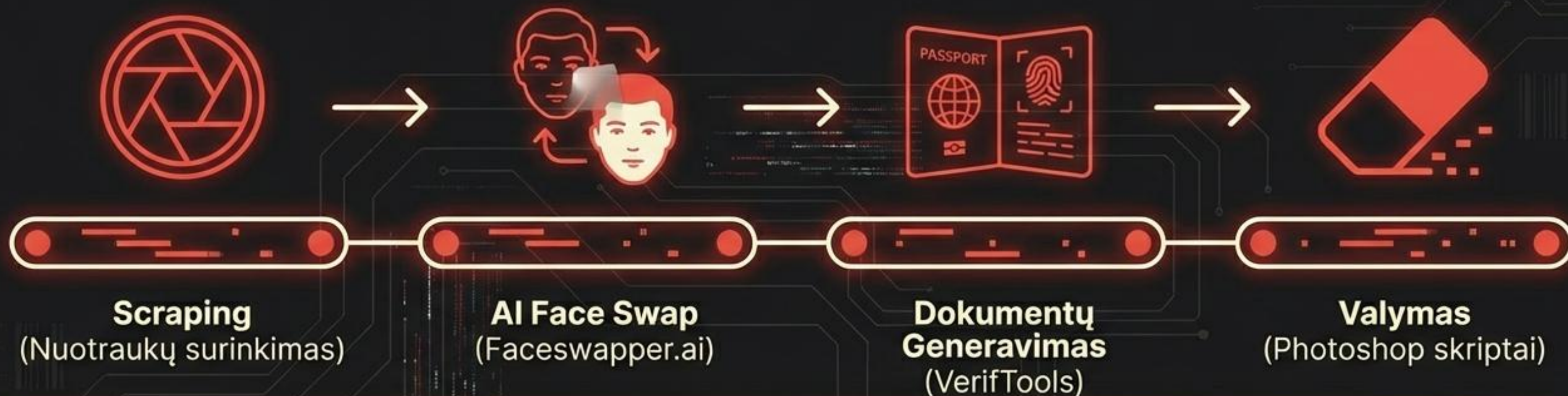
Pinigų Plovimas:

Kiniškos banko sąskaitos -> Kriptovaliutos.



Kontrolė: Vadovas turi visų darbuotojų slaptažodžius ir nuotolinę prieigą.

Atvejo Analizė: Tapatybių Gamykla



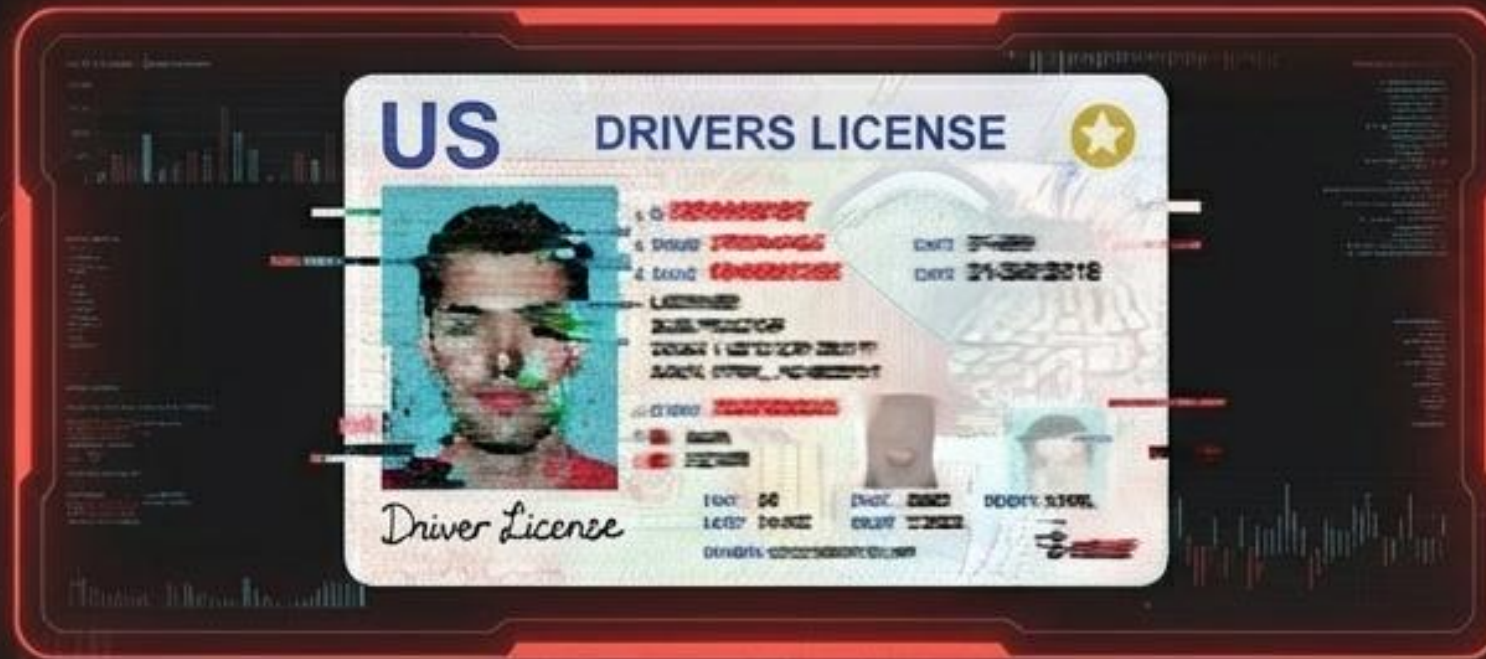
135+ Sintetinės Tapatybės

(Rytų Europa, Pietryčių Azija)

Sėkmingumo rodiklis: **~40%** tapatybės patikros bandymų.

Atvejo Analizė: Individualūs Operatoriai

JAV Fokusas



- Valdo 21 skirtingą personą.
- Vogti duomenys: **8000** JAV svetingumo sektoriaus darbuotojų.
- **Taktika:** Savo nuotraukos įklijavimas į vogtus JAV dokumentus.

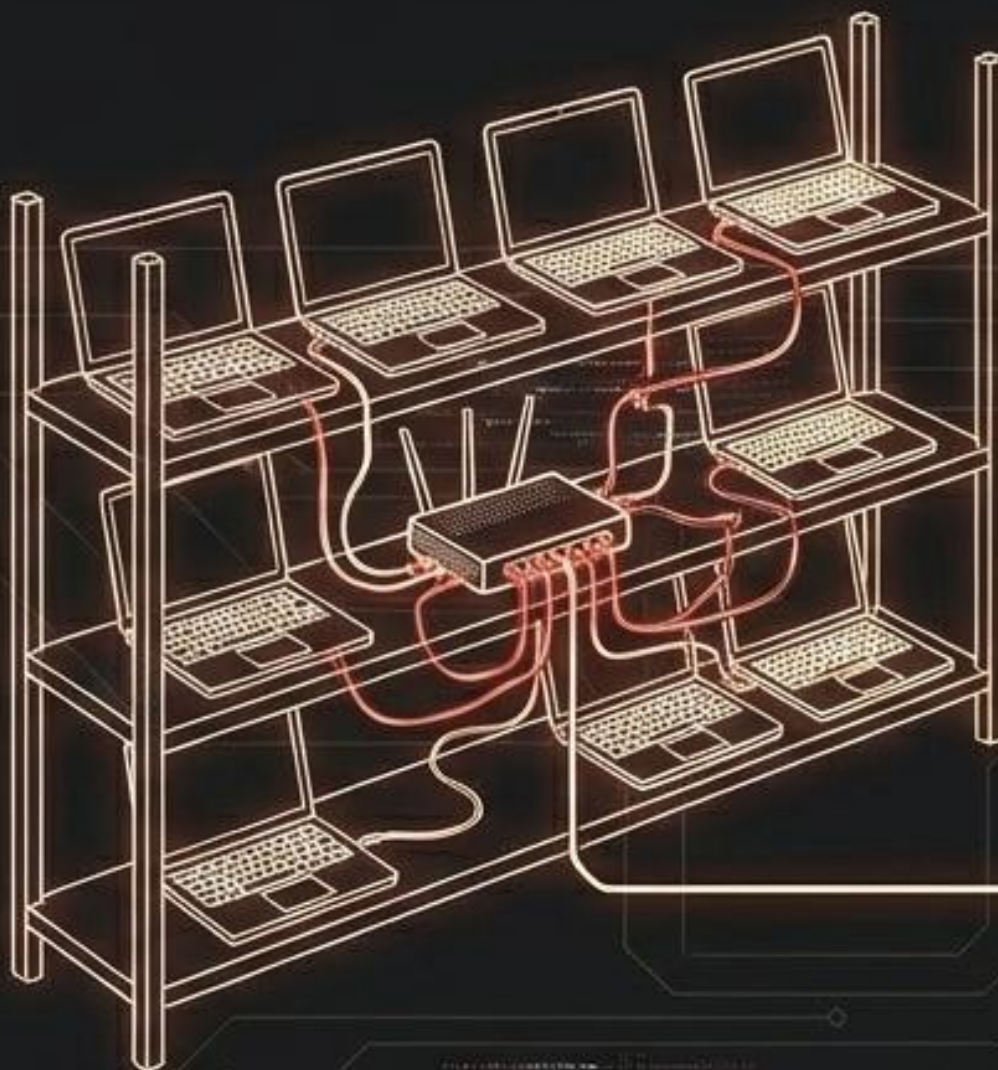
Maskvos Pėdsakas



- Geolokacija: **Maskva, Jakimankos rajonas.**
- **Tikslas:** Pilno etato darbas JAV/JK įmonėse.
- **Taktika:** Samdo tarpininkus tik techninės įrangos ('laptop farms') laikymui.

Pagalbininkų (Facilitators) Tinklas

Vietiniai
gyventojai
(JAV, JK)



Funkcija: Elektra,
internetas, fizinė
įranga

Rizika: Mažesnė,
nes tarpininkai nežino
tapatybės

Programišiai ieško techninių tarpininkų, o ne tapatybės bendrininkų.
Tai leidžia apeiti IP blokavimus ir geolokacines apsaugas.

Indikatoriai (Indicators of Compromise)

1. **[SUSPICIOUS] in Alert Vermilion (#E03C31)** JetBrains Mono
Ryšiai su `api.npoint.io` arba `vercel.app` subdomenais iš vidinių sistemų.
2. **[MALICIOUS] in Alert Vermilion** JetBrains Mono
Neįprasti `Function.constructor` iškvietai.
 - Koduoti kintamieji `.env` failuose (pvz: `RUNTIME\_CONFIG\_API\_KEY`).
3. **[WARNING] in Amber (#FFC107)** JetBrains Mono
`npm` paketai, sukurti prieš pat projekto pradžia.
4. **[CHECK] in Blue (#4285F4)** JetBrains Mono
Kandidatai su neaktyviomis nuorodomis CV arba portfolio.



Mitigacija ir Gynyba



Sandymo Procesas

Griežta vaizdo patikra („liveness checks“).
Atsargumas su kandidatais, vengiančiais kameros.



Kodo Saugumas

Atsiųstus projektus leisti tik izoliuotoje „sandbox“ aplinkoje. Niekada ne darbiname tinkle.



Stebėsena

Stebėti neįprastą srautą į failų dalinimosi ir debesijos paslaugas.

Išvados: Nuolatinė Evoliucija

Grėsmė perėjo nuo paprasto sukčiavimo prie sudėtingų DI operacijų ir „gyvų“ interviu imitacijų.

Tai ne automatizuoti botai – tai motyvuoti žmonės, dirbantys pilnu etatu.

**BŪTINAS NUOLATINIS BUDRUMAS IR DALIJIMASIS
ŽVALGYBINE INFORMACIJA.**

[END OF BRIEFING]